Attaques BGP : définition, exemples et impacts

Une annonce mensongère (préfixe ou chemin) peut détourner, intercepter ou couper du trafic Internet.

Définition

Une attaque BGP (hijack / route leak) consiste à annoncer des routes non autorisées
afin de faire préférer un chemin (ou un préfixe) contrôlé par l'attaquant.

Deux leviers

1) Même préfixe, chemin plus attractif (ex. AS-PATH plus court)
2) Préfixe plus spécifique (subprefix hijack)

Mise en place (vue globale)

1) Accès à un AS / peering (ou compromission)
2) Annonce de (sous-)préfixes
3) Propagation → trafic redirigé, intercepté ou blackholé

Impacts

- Interruption de service (blackhole / mauvais chemin)
- Interception / MITM (vol de sessions, phishing)
- Détournement DNS et pages frauduleuses
- Latence + instabilité globale
- Impact financier & réputation

Exemples réels

- 2008 : Pakistan Telecom annonce un sous-préfixe de YouTube → trafic détourné
- 2018 : détournement BGP visant Route 53 → redirection vers un faux MyEtherWallet
- 2019 : route leak (Verizon + optimizer) → indisponibilité massive (Cloudflare & autres)

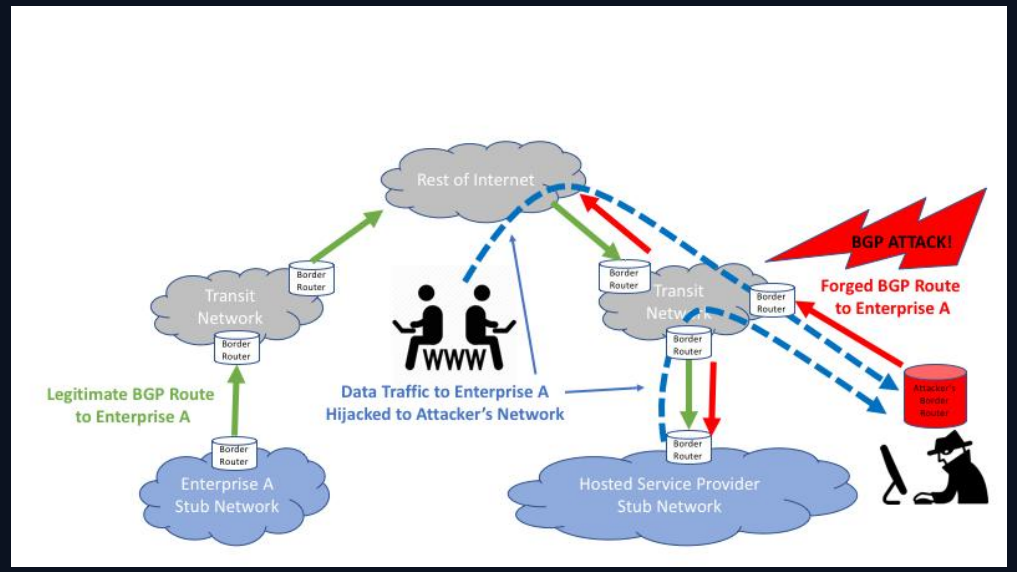


Illustration (NIST) : exemple de détournement de route BGP

Attaque 1 — même préfixe, AS-PATH plus court

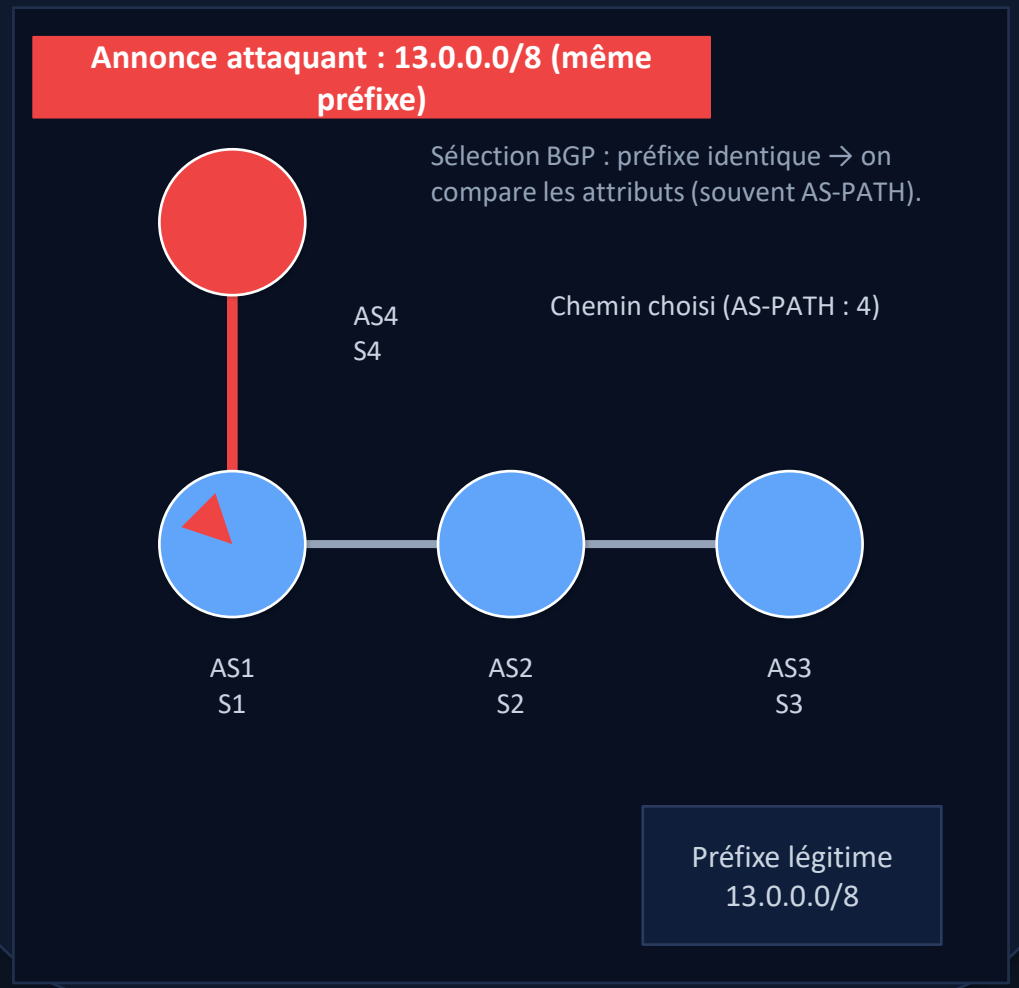
L'attaquant annonce le même préfixe que la victime et gagne via la sélection BGP (chemin "plus attractif").

Principe

- L'AS4 annonce exactement le même préfixe que l'AS3 (ex. 13.0.0.0/8).
- Comme le préfixe est identique, la décision BGP compare des attributs (local-pref, AS-PATH, …).
- Un AS-PATH plus court est généralement préféré.

- Résultat : le trafic vers 13.0.0.0/8 part vers AS4, même si l'origine légitime est AS3.

Topologie Mininet + effet

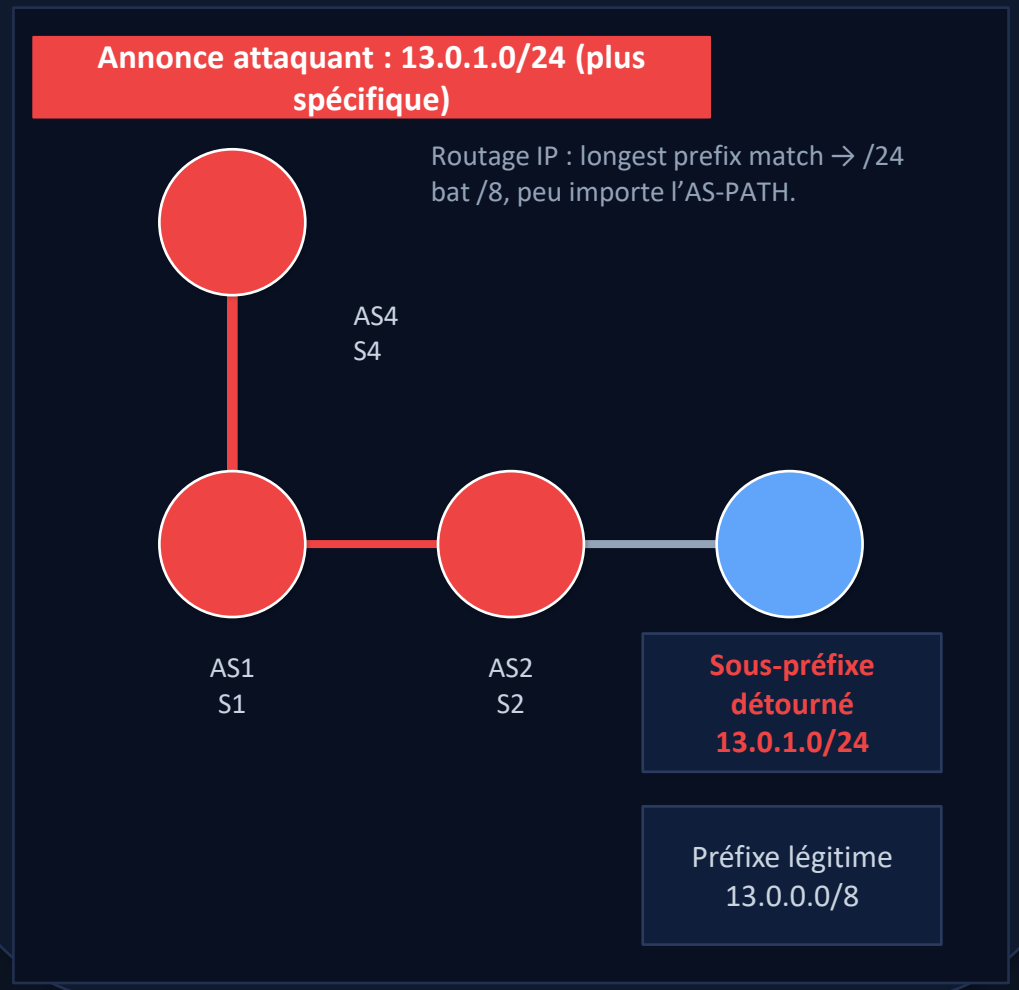


Attaque 2 — préfixe plus spécifique (subprefix hijack)

L'attaquant annonce un sous-préfixe (ex. /24) inclus dans le bloc légitime (ex. /8).

Principe

- L'AS3 reste l'origine du bloc 13.0.0.0/8, mais l'AS4 annonce un sous-ensemble (ex. 13.0.1.0/24).
- Même si l'AS-PATH est moins bon, le routage IP applique la règle "longest prefix match".
- Donc, pour les adresses 13.0.1.x, le /24 est préféré au /8.

- Résultat : détournement partiel (seulement la partie plus spécifique)

Topologie + effet "/24 bat /8"